

Portfolio Security Report

Consolidated Batch Summary

Company:

ACME Cyber Risk

Report

Type:

Consolidated

Timestamp:

—

Session:

Z FQ JW

Executive Summary

The overall risk posture across all repositories indicates a need for immediate attention, with 100% of repositories containing flagged files. Key findings include:

- 1 repository scanned.
- 1,432 total files scanned.
- 9 flagged files, representing 0.63% of total files.
- 100% of repositories have findings.
- Top categories: **high_entropy_candidate** (7 instances), **gha_uses_floating** (2 instances).
- All findings are of **medium** severity.

Portfolio-Level Statistics

Metric	Total	Rate/Percentage
Repositories	1	100%
Files Scanned	1,432	-
Flagged Files	9	0.63%
Repos with Findings	1	100%

Category	Count	% of Total
High Entropy Candidate	7	77.78%
GHA Uses Floating	2	22.22%

- Top repository by flagged count: **CherryHQ/cherry-studio** (9 flagged files).
- Median flagged files per repo: 9.
- 95th-percentile flagged files per repo: 9.

Systemic Risks & Themes

- **High Entropy Candidates:** Found in **CherryHQ/cherry-studio**, indicating potential secret exposure.
- **GHA Uses Floating:** Detected in **CherryHQ/cherry-studio**, suggesting reliance on non-pinned dependencies.

Prioritized Recommendations

- **P0:** Immediate removal or rotation of exposed secrets in **CherryHQ/cherry-studio**.
Success criteria: No high entropy findings in subsequent scans.
- **P1:** Implement dependency pinning in CI/CD pipelines to prevent floating versions.
Success criteria: No GHA uses floating findings.
- **P2:** Enhance static analysis tooling to include dynamic checks for secret usage patterns.

Notable Repositories

- **Higher-Risk:** **CherryHQ/cherry-studio** due to high entropy candidates and floating dependencies.
- **Standout-Safe:** None identified in this batch.

Methodology Notes

- Scan scope included static analysis only; dynamic behaviors were not evaluated.
- Evidence excerpts are redacted or partial to maintain confidentiality.
- Assumptions: Findings prioritized over flags; if both absent, used stats.flagged_count or defaulted to 0.